

Borla

Testing Report

Student: **George Boadu Junior**

Student ID: **22427354**

Course: CSCD 602 — Advanced Software Engineering, University of Ghana

Document: Testing_Report.pdf · Version 1.0 · 13 August 2026

1. Test strategy

Four layers, in the order they were actually run during the build:

1. **Unit tests** (Vitest) — pure functions with no I/O: OTP hashing/verification, the quiet-hours time-window predicate.
2. **Integration tests** (Vitest + Supertest) — the real Express app (`createApp()`) against a real PostgreSQL+PostGIS instance (a local Docker container running the exact same `postgis/postgis:16-3.4` image family Render uses), covering every route's happy path and its most important failure mode.
3. **Component tests** (Vitest + React Testing Library) — client-side rendering/interaction logic in isolation, with `fetch` mocked.
4. **System / User Acceptance Testing** — manual, scripted, end-to-end walkthroughs against the running application (server + Postgres + browser), exercising both roles and the admin console exactly as a real user would.

Security and usability checks (§5, §6) were folded into the same passes rather than run as a separate phase, which is appropriate at this scale.

2. Automated test results

2.1 Server (`npm run test -w server`)

```
✓ test/unit/otp.test.ts (3 tests)
✓ test/unit/quietHours.test.ts (4 tests)
✓ test/unit/sms.test.ts (3 tests)
✓ test/integration/auth.test.ts (8 tests)
✓ test/integration/broadcasts.test.ts (4 tests)
✓ test/integration/requests.test.ts (4 tests)
✓ test/integration/reviews.test.ts (4 tests)
✓ test/integration/admin.test.ts (4 tests)

Test Files  8 passed (8)
Tests      34 passed (34)
Duration   14.60s
```

2.2 Client (`npm run test -w client`)

```
✓ src/pages/StatusChip.test.tsx (2 tests)
✓ src/components/ReviewForm.test.tsx (2 tests)

Test Files  2 passed (2)
Tests      4 passed (4)
```

Total: 38/38 automated tests passing at time of submission. Re-run with `npm test` from the repository root (requires a reachable Postgres+PostGIS — see `README.md`).

3. Test case log

Representative cases spanning all four rubric areas (functional, unit, integration, system/UAT). "Actual result" reflects the real run, including two real defects caught and fixed during development (rows T-08 and T-19).

#	Test case	Layer	Expected result	Actual result	Pass/Fail
T-01	Request an OTP for a brand-new phone number with no <code>role</code>	Integration	<code>400</code> — role required to sign up	<code>400</code> returned with actionable message	Pass
T-02	Request an OTP, verify with the correct code	Integration	New user created, <code>access / refresh</code> issued	User created with <code>role='household'</code> , tokens returned	Pass
T-03	Verify with an incorrect 6-digit code	Integration	<code>400</code> , attempt counter incremented	<code>400</code> returned	Pass
T-04	Re-use an already-consumed OTP code	Integration	<code>400</code> — rejected as already used	<code>400</code> returned	Pass
T-05	<code>GET /auth/me</code> with no bearer token	Integration	<code>401</code>	<code>401</code> returned	Pass
T-06	<code>GET /auth/me</code> with a valid token	Integration	<code>200</code> with role-specific profile	<code>200</code> , <code>profile.alert_radius_m</code> present for household	Pass
T-07	Admin login with a non-admin phone number	Integration	<code>401</code>	<code>401</code> returned	Pass
T-08	(defect) OTP-verify signup path for a brand-new number	Integration (found while writing T-02)	New user row created with the requested role	First implementation threw <code>role_missing</code> inside a dead transaction branch and never created the user — see §4	Fail → Fixed , now Pass
T-09	Collector attempts to go online before admin verification	Integration	<code>403</code>	<code>403</code> returned	Pass
T-10	Verified + online collector, household broadcasts nearby	Integration	Fan-out notifies ≥1 collector; pin appears in that collector's <code>/pins/nearby</code>	<code>notifiedCollectors: 1</code> ; pin present with correct <code>distance_m</code>	Pass
T-11	Household creates a second broadcast while one is active	Integration	<code>409</code>	<code>409</code> returned	Pass
T-12	Collector role attempts to create a broadcast	Integration	<code>403</code> (role guard)	<code>403</code> returned	Pass
T-13	Household requests an offline collector	Integration	<code>409</code>	<code>409</code> returned	Pass

#	Test case	Layer	Expected result	Actual result	Pass/Fail
T-14	Full request lifecycle: requested → seen → accepted, contact reveal timing	Integration	Phone numbers absent pre-accept, present post-accept	Confirmed via direct field assertion pre/post	Pass
T-15	Reject a request after it was already accepted	Integration	409 , status stays accepted (not resurrected to rejected)	409 returned, status unchanged	Pass
T-16	A collector who wasn't the request's target tries to accept it	Integration	409 (conditional update matches 0 rows)	409 returned	Pass
T-17	Review submitted against a request that is not yet accepted	Integration	400	400 returned	Pass
T-18	Duplicate review on the same accepted request	Integration	409 (unique constraint)	409 returned	Pass
T-19	(defect) Reply to a review before it is moderation-visible	Integration (found while writing this test)	400 — cannot reply to a non-visible review	First implementation only checked subject_id , not status , allowing a reply on a still-pending review — see §4	Fail → Fixed , now Pass
T-20	Second reply attempt on an already-replied review	Integration	409 (one reply per review)	409 returned	Pass
T-21	Admin verifies a collector; collector can now go online; action appears in audit log	Integration	200 → 200 ; audit_log contains verify_collector	All three confirmed	Pass
T-22	Admin suspends a household; suspended user's /auth/me is blocked; reinstate restores access	Integration	403 while suspended, 200 after reinstatement	Confirmed	Pass
T-23	Admin edits an unknown config key	Integration	404	404 returned	Pass
T-24	Full system walkthrough : household broadcast → collector sees pin on map →	System/UAT (manual, live server)	Pin visible then gone from collector's feed	Verified against the running app with real curl/browser sessions	Pass

#	Test case	Layer	Expected result	Actual result	Pass/Fail
	household clears it				
T-25	Full system walkthrough : direct request → accept → contact reveal → review both sides → double-blind release fires within the 2-minute sweep window	System/UAT (manual, live server)	Both reviews become visible simultaneously , rating aggregates recompute correctly	<code>rating_avg</code> / <code>rating_count</code> confirmed via direct DB query after the sweep ran	Pass
T-26	Manual moderation fallback (no <code>GEMINI_API_KEY</code> set)	System/UAT	Submitted reviews appear in <code>/admin/moderation/queue</code> → <code>awaitingManual</code> , not silently published	Confirmed — both test reviews appeared, required explicit admin approval	Pass
T-27	Quiet-hours predicate across a midnight-wrapping window	Unit	Inside/outside window classified correctly at boundaries	4/4 boundary cases correct	Pass
T-28	OTP hash/verify round-trip and mismatch rejection	Unit	Correct code verifies true, wrong code false	Both confirmed	Pass
T-29	<code>StatusChip</code> renders the correct label for every request status + an unknown fallback	Component	Exact label text present for each of 5 statuses + fallback	Confirmed	Pass
T-30	<code>ReviewForm</code> treats a 409 (already reviewed) the same as success	Component	Renders the thank-you state, not an error banner	Confirmed	Pass
T-31	Production client build (<code>vite build</code>) and server build (<code>tsc</code>) both compile clean	Build/System	Zero TypeScript errors, bundle produced	Both confirmed (<code>tsc --noEmit</code> clean; <code>dist/</code> produced)	Pass
T-32	GiantSMS phone-number normalisation (<code>+233...</code> / <code>233...</code> → local <code>0...</code> form)	Unit	Both prefixes normalise to the same local number; an already-local number is untouched	3/3 cases correct	Pass
T-33	GiantSMS end-to-end request	System (live)	Gateway accepts the send request	<code>POST /api/auth/otp/request</code> against	Pass (partial — see <code>Technical_Debt_Plan.md</code>)

#	Test case	Layer	Expected result	Actual result	Pass/Fail
	against the real funded account, production			https://borla.onrender.com returned <code>{"delivered":true}</code> — GiantSMS accepted the request at the HTTP layer. Actual handset receipt not visually confirmed (test number is a placeholder, not a live phone)	TD-02)

4. Defects found during development

Defect	Where	Root cause	Corrective action
D-01	<code>server/src/utils/jwt.ts</code>	<code>jsonwebtoken</code> 's TypeScript types don't accept a plain <code>string</code> for <code>expiresIn</code> (expects its own <code>StringValue</code> literal union)	Cast through <code>jwt.SignOptions["expiresIn"]</code> explicitly rather than loosening the type globally
D-02	<code>server/src/modules/auth/routes.ts</code> (OTP verify)	An early draft wrapped user-creation in a transaction block that threw a sentinel error (<code>role_missing</code>) to short-circuit — but the <code>catch</code> swallowed it without ever inserting the user, so first-time signup silently returned an "unexpected signup state" error	Rewritten as a straight-line <code>if (!user) { ...INSERT... }</code> with no transaction/sentinel-error indirection; covered by T-02/T-08
D-03	<code>server/src/seed.ts</code>	First draft referenced a non-existent <code>verified_note</code> column on <code>collectors</code> (copy-paste artefact) wrapped in a silent <code>.catch()</code> fallback that masked the real error	Removed the phantom column and the <code>.catch()</code> swallow entirely; seed now fails loudly if it ever breaks again
D-04	<code>server/src/modules/reviews/routes.ts</code> (reply endpoint)	Only checked <code>review.subject_id === user.id</code> , not <code>review.status === 'visible'</code> , so a reply could be posted on a still-hidden/pending review	Added the status check; covered by T-19

All four were caught by writing the test suite immediately after the corresponding feature, not by separate manual QA — direct evidence for why TD-10 (test depth) is listed as "scheduled," not "critical": the practice worked, it just hasn't been extended to every corner of the app yet.

5. Security testing

Check	Method	Result
Every mutating/reading-sensitive route requires a valid JWT	Automated (T-05, T-12, T-16, T-22) + manual <code>curl</code> without a token	Consistently <code>401</code> / <code>403</code>

Check	Method	Result
SQL injection surface	Code review — every query in <code>server/src/modules/**</code> uses parameterised <code>\$1..\$n</code> placeholders, none concatenate user input into SQL	No string-built SQL found
OTP brute-force / spam	Code review + manual test	5-per-10-minutes request cap and a 5-attempt verify cap are enforced (<code>otp/routes.ts</code>); acknowledged as coarse, see TD-05
Role escalation (collector calling household-only routes, etc.)	Automated (T-12) + manual <code>curl</code> across all role-gated routes	Consistently <code>403</code>
Contact information leakage pre-accept	Automated (T-14)	Phone fields verified absent from the JSON payload itself (not just hidden in the UI) before acceptance
Secrets handling	Code review	JWT secrets and the Gemini key are read from environment variables only, never committed (<code>.env</code> is git-ignored, <code>.env.example</code> has placeholders)

6. Usability testing

A short heuristic pass against the approved `borla_UI_design.html` design system: tap targets $\geq 44\text{px}$ (`.btn` padding), icon-first primary actions ("🔔 I HAVE WASTE", "🌐 Go online"), a single primary action per screen, and colour contrast matching the approved palette (green/ marigold/coral on a warm paper background). Confirmed manually in-browser at mobile viewport widths (390px, 414px) and desktop.

7. Performance testing

Out of scope at pilot scale by design (see SRS NFR discussion) — the one performance-relevant check performed was confirming the PostGIS `ST_DWithin` / `GEOSEARCH` -equivalent nearby queries use the `GIST` index created in `001_init.sql` (`EXPLAIN` on `broadcasts_loc_gix` confirmed an index scan, not a sequential scan, even against the small seeded dataset).

8. What was NOT tested (honestly stated, ties to Technical_Debt_Plan.md TD-10)

Visual confirmation of a GiantSMS text actually arriving on a real handset (T-33 confirmed the gateway *accepts* the request in production; the seeded demo number is a placeholder, not a live phone someone was watching); concurrent double-accept under real network race conditions (only sequential-call idempotency is proven); load/stress testing; cross-browser automated testing (manual only); the four `CollectorHome` / `HouseholdHome` / `AdminDashboard` / `Profile` React pages have no component tests yet, only the two smaller components (`StatusChip` , `ReviewForm`).